SOC L1 LAB · REGRESSION-001

REGRESSION-001 — Full Suite Under Legitimate Load

Six scenarios, real VM activity, and the one rule that silently stopped firing

INCIDENT	REGRESSION-001 — All scenarios under legitimate load
REPORT DATE	2026-11-01
CLASSIFICATION	Lab exercise — sanitized for publication
ENVIRONMENT	Wazuh 4.14.7 · Debian 12 · QEMU/KVM
SEVERITY	High (one detection gap)

Independent portfolio lab. No production systems, client data, or real credentials.

Contents

1. Purpose
2. Method
3. Headline results
4. The one real bug: 100122 was outranked
5. Expected false positives, confirmed
6. New noise findings
7. What was not changed
8. Changes made
9. Evidence
10. Lessons
11. Cleanup state

Type	Regression / interaction test
Scope	All six scenarios, one Debian VM
Date	2026-10-31, 23:51–23:53 UTC
Result	One real detection gap fixed; several known/expected false positives confirmed; one stock sensor false positive
Related	`docs/evidence/REGRESSION-001-*`, `rules/local_rules.xml`, `rules/inc-002-rules.md`

---

1. Purpose

Run every scenario again, but with realistic legitimate activity from the victim in the same window. The question was not "does each rule fire?" — it was "does anything fire when it should not, or fail to fire when it should?"

The legitimate activity was not synthetic `curl` noise. It included:

- `apt-get update` and installing `sysstat` and `unattended-upgrades`;
- a real PHP deployment (`index.php`, `health.php`), a backup, and a temp copy;
- a legitimate maintenance cron file and systemd timer, enabled then removed;
- an authorized SSH key rotation for `analyst`;
- routine SSH logins and web traffic throughout.

---

2. Method

Marks were written before each phase:

Mark	Phase
23:51:49	Legitimate activity starts
23:51:55	After package installs
23:51:58	After PHP deployment
23:52:03	After legitimate cron/systemd
23:52:07	After key rotation
23:52:19	INC-001 (first attempt; hydra failed)
23:52:20	INC-002
23:52:21	INC-003
23:52:24	INC-004
23:52:25	INC-005
23:52:43–23:53:21	INC-001 re-run with a valid wordlist

Alerts were exported from the manager and classified by rule ID, path, command, and signature. The raw marks are in `docs/evidence/REGRESSION-001-marks.txt`.

---

3. Headline results

Rule	Hits	Expected TP	Known FP	Unexpected
100120 authorized_keys	6	4 (test key append/restore)	2 (legit rotation)	—
100121 usermod privileged group	1	1 (reg-ops)	—	—
100122 service-account login	**0**	1 (svc-backup)	—	**GAP**
100123–100126 variants	0	0	—	—
100127 `.php?cmd=`	2	1 (reg-shell)	1 (legit `cmd=status`)	—
100128 `.php` file	5	1 (reg-shell)	4 (deploy, backup, temp)	—
100129 cron file	4	1 (reg-updates)	2 package + 1 maintenance	`.dpkg-new` noise
100130 systemd change	8	3 (reg-update)	5 (package + maintenance)	package timers
86601 Suricata wrapper	154	150 LAB SCAN	1 stock ET SCAN SSH	stock DNS spoof
5763 / 40112 / 5760	1 / 3 / 20	brute-force chain	analyst noise	—

The strongest result: **100122 never fired for the `svc-backup` login.** The alert was produced by stock 40112 instead.

---

4. The one real bug: 100122 was outranked

What happened

After 20 failed passwords, `Accepted password for svc-backup` matched stock rule **40112** ("Multiple authentication failures followed by a success"). Rule 100122 was a sibling of 40112 and never evaluated. The service-account login was invisible.

This is the same precedence pattern seen earlier with custom correlation rules: a stock parent matches first, and a sibling local rule does not get a turn.

Fix

Added **100131**, a child of 40112 with the same `for svc-` match:

```
<rule id="100131" level="12">
  <if_sid>40112</if_sid>
  <match>for svc-</match>
  <description>SSH: service-account login after brute-force correlation</description>
  <mitre><id>T1078</id><id>T1110</id></mitre>
  <group>authentication_success,brute_force,</group>
</rule>
```

Validated with `wazuh-logtest`:

Input	Rule
8 failures + `Accepted password for svc-test`	**100131**
`Accepted password for svc-test` with no failures	**100122**

100122 remains for the no-failure case; 100131 covers the brute-force case. Two rules, one intent, no blind spot.

---

5. Expected false positives, confirmed

These are known and documented, not regressions:

Activity	Rule	Why
Legit `index.php` deploy/update/backup/temp	100128	Matches any `.php` substring
Legit `index.php?cmd=status`	100127	First-position `cmd` parameter
Authorized key rotation	100120	File name match
Legit maintenance cron and timer	100129 / 100130	Change monitoring
`sysstat` package install	100129 / 100130	Package cron file + timer symlinks

No unexpected hits from 100121–100126 during package installation. System users created by packages did not land in `sudo` / `wheel` / `admin`.

---

6. New noise findings

6.1 `100129` fires on `.dpkg-new`

Package installation produced:

```
/etc/cron.d/sysstat.dpkg-new added
/etc/cron.d/sysstat added
```

The transient `.dpkg-new` file is not a persistence artifact; it is dpkg staging. It is noise, but it is also evidence of a package transaction.

Options:

- ignore `*.dpkg-new` / `*.dpkg-old` in the FIM path;
- keep it and match the alert to the package transaction;
- route package windows to a lower-priority queue.

6.2 `100130` fires on package timer symlinks

Installing `sysstat` created:

```
/etc/systemd/system/sysstat.service.wants/sysstat-collect.timer
/etc/systemd/system/sysstat.service.wants/sysstat-summary.timer
```

These are legitimate enable links. They reinforce the recommendation to split 100130 into unit-body (level 12) and enable-link (level 5) rules.

6.3 Stock Suricata false positive on normal SSH

Rule 86601 fired once on:

```
10.0.2.2 -> 10.0.2.15:22
ET SCAN Potential SSH Scan
```

That was the routine SSH login loop, not a scan. It is a **stock ET Open** rule, not the local LAB SCAN rule. The local rule (sid 1000001) did not fire on normal SSH or on apt traffic. It fired only on the nmap scan and its delayed retransmits.

6.4 Delayed scan retransmits

The nmap run was at 23:52:25, but four LAB SCAN alerts appeared at 23:53:10 with scan ports (1069, 5666, 7000). Those are consistent with delayed/retransmitted SYNs from the filtered scan, not the SSH brute force. A triage window must allow for late events.

---

7. What was not changed

Finding	Decision
100128 on legitimate deployments/backups	Keep; route to deployment triage
100127 on legitimate `cmd`	Keep; allow-list known paths
100120 on key rotation	Keep; key-rotation change ticket
100129/100130 on legitimate maintenance	Keep; change-aware queue
100129 on `.dpkg-new`	Document; consider FIM ignore
100130 on package enable links	Document; split rule backlog
Stock ET SCAN SSH noise	Not our rule; tune ET or accept

The principle: a rule that is correct but noisy should be **routed and contextualised**, not suppressed. Suppression hides the next real event.

---

8. Changes made

Change	Reason
Added 100131	100122 was outranked by 40112
Updated `rules/inc-002-rules.md`	Document precedence and 100131
Regenerated rules PDF	Keep the paper in sync
Recorded this report and evidence	Regression audit trail

No other rule was changed. The known false positives remain documented in their respective guides.

---

9. Evidence

File	Contents
`docs/evidence/REGRESSION-001-marks.txt`	Phase timestamps
`docs/evidence/REGRESSION-001-alerts.json`	188 relevant alerts
`docs/evidence/REGRESSION-001-suricata.json`	153 alert events (signatures by type)

Suricata signature breakdown:

```
150  LAB SCAN outbound SYN sweep
  1  GPL DNS SPOOF query response ...
```

```
1  ET SCAN Potential SSH Scan
1  ET SCAN LibSSH Based Frequent SSH Connections Likely BruteForce Attack
```

---

10. Lessons

- **Rule precedence is a detection property.** A correct rule can be silent because a stock parent matched first. Test the chain, not just the rule.
- **Package installs are a noise source.** `.dpkg-new` and enable symlinks are normal.
- **A generic wrapper hides the signature.** 86601 is only as useful as the Suricata signature behind it.
- **Timing buffers matter.** Delayed retransmits can move scan alerts into the next phase.
- **Known false positives are not failures.** They are routing requirements.

---

11. Cleanup state

- Webroot: `index.nginx-debian.html` only.
- Test users (`reg-ops`) removed; `sudo` group back to `analyst,debian` .
- `svc-backup` authorized_keys restored to its original one line.
- Test cron files and units removed; the approved `log-maintenance` change from INC-006 remains by design.
- `sysstat` and `unattended-upgrades` remain installed from the legitimate package noise; remove them if a pristine VM is required.
- Background noise loops stopped.